

THE FREE EDITION · 2026

The PCI SAQ Workbook

Plain-English checklists for SAQ A, A-EP, B, and D — plus an 8-step decision guide and a 15-term PCI glossary. Built for the people actually trying to get compliant, not the people writing the standards.

FREE · MIT LICENSED

Maintained by **Paytia**
PCI-compliant phone payments

paytia.com/phone-payments
[Live](#) · [GitHub Pages](#)

Contents

How to use this workbook	3
Which SAQ do I need? — 8-step guide	5
SAQ A — Card-not-present, fully outsourced	9
SAQ A-EP — E-commerce with iframe/redirect	13
SAQ B — Imprint and dial-out terminals	19
SAQ D — Comprehensive (high-impact subset)	23
PCI glossary — 15 terms in plain English	31
About Paytia	35

How to use this workbook

The official PCI DSS Self-Assessment Questionnaires are written for QSAs and security professionals. If you're a finance director or operations manager who's suddenly responsible for PCI, they're rough going.

This workbook translates the highest-impact controls from SAQ A, A-EP, B, and D into language a busy ops manager can actually use, with the evidence you'll need for each one.

Three things to know first

- 1. This is a starting point, not an audit.** Use it to scope your work, build a checklist for your team, and prepare for a conversation with a Qualified Security Assessor. Your QSA still has the final word on which SAQ applies and whether you've met it.
- 2. Start with "Which SAQ?".** Most merchants pick the wrong SAQ on their first attempt — usually because they assume "outsourced means SAQ A" without checking the conditions. Work through the 8-step decision guide first.
- 3. Phone payments are the trap.** If your business takes card payments over the phone, the agent typing the card number into a CRM during the call brings the entire call recording, the agent's PC, the phone system, and most of the office network into PCI scope. That single behaviour can move you from SAQ A to SAQ D — from 16 controls to 330+.

How phone-payment descope works. A descope solution like Paytia intercepts card details before they reach the agent or the call recording. The customer types the card number on their phone keypad; DTMF tones are captured by a PCI-compliant payment system and replaced with masked tones in the recording. Agents never hear or see the card data — and the call goes back to SAQ A scope.

Read more: paytia.com/phone-payments

How the checklists work

Each SAQ section lists the high-impact controls grouped by topic. For each control you'll see: the official PCI DSS reference number, a plain-English requirement, what it actually means in practice, and (where useful) what evidence you'll need on file.

Print this PDF, tick the boxes as you go, and use it as the working document for your assessment. The full interactive version with progress tracking is at paytia-comply.github.io/paytia-saq-checklist.

SECTION 1

Which SAQ do I need?

The PCI Council publishes nine SAQs. Most merchants only need to consider five. Work through these eight questions in order — the first “yes” that matches is your starting point.

8-step decision guide

STEP 1

Do you take any card payments at all?

Yes → Continue.

No → PCI doesn't apply. You can stop here.

STEP 2

Are all your card payments handled by a third party that you redirect customers to?

Yes → If your e-commerce flow is a redirect or processor-served iframe and you never touch card data, you're a candidate for SAQ A.

No → Continue — you'll need a more comprehensive SAQ.

STEP 3

Do you have your own e-commerce checkout page that loads a third-party payment iframe?

Yes → SAQ A-EP. Your server controls the page, so it's in scope even though card data goes straight to the processor.

No → Continue.

STEP 4

Do you take payments only through standalone, dial-out (PSTN) terminals or imprint machines?

Yes → SAQ B. No internet, no e-commerce.

No → Continue.

STEP 5

Do you take payments only through standalone IP-connected payment terminals?

Yes → SAQ B-IP. Same as B but the terminal is on your IP network.

No → Continue.

STEP 6

Do you take payments through a virtual terminal accessed only via a single, dedicated, isolated computer?

Yes → SAQ C-VT.

No → Continue.

STEP 7

Do you have a payment application that's connected to the internet but stored data is segmented out?

Yes → SAQ C.

No → Continue.

STEP 8

Do you use a PCI-listed P2PE (point-to-point encryption) solution?

Yes → SAQ P2PE — covers merchants using only validated P2PE solutions.

No → You're on SAQ D — the catch-all. This includes most phone-payment merchants without a descope solution.

A note on phone payments. If your business takes card payments over the phone, the SAQ guide on its own can mislead you. The agent typing a card number into a CRM during a call pulls the entire call recording, the agent's PC, the phone system, and most of the office network into PCI scope. That bumps you to SAQ D regardless of what the rest of your environment looks like. A descope solution like Paytia intercepts the card details before they reach the agent or the recording — typically reducing scope from SAQ D back down to SAQ A.

SECTION 2 · ~16 CONTROLS

SAQ A

Card-not-present, fully outsourced. The lightest SAQ — for merchants who never see, store, or transmit card data because a third party handles all of it.

SAQ A — Checklist

Roughly 16 controls covering policy, third-party management, and physical security of any backup terminals. SAQ A does not cover phone payments where agents type card numbers into a CRM — if that's you, you'll need a descope solution to stay on SAQ A.

Policy & scope

☐ **12.1 Maintain an information security policy**

Write down how your business handles security. One short document, reviewed once a year, signed off by a director. It doesn't need to be 80 pages.

Evidence: *Signed policy document, last-reviewed date*

☐ **12.4 Define PCI responsibilities**

Name the person who owns PCI in your business. Could be the finance director, ops manager, whoever. Just one named person, written down.

Evidence: *Org chart or job description naming the role*

☐ **12.8 Manage third-party service providers**

List every supplier that touches card data — your payment processor, hosting provider, the iframe vendor. Get their AOC (Attestation of Compliance) once a year.

Evidence: *Supplier list + current AOCs on file*

Outsourcing & iframe controls

☐ **2.4.a Confirm payment is fully outsourced**

Your website redirects customers to your payment processor's page, OR uses an iframe served entirely from the processor. You never see the card number, not even briefly.

Evidence: *Architecture diagram showing redirect/iframe flow*

☐ **9.5 Protect payment terminals from tampering**

If you have any physical card terminals (e.g. for backup), keep a list of them, check them weekly for tampering, and train staff on what to look for.

Evidence: *Terminal inventory + inspection log*

Incident response

☐ **12.10.1 Have a written incident response plan**

Two pages is fine. Who do you call if you suspect a breach? How do you contact the card brands? Test it once a year with a tabletop exercise.

Evidence: *Plan document + last tabletop exercise notes*

☐ **12.10.5 Monitor security alerts from your providers**

If your processor or hosting provider sends a security bulletin, somebody reads it within 24 hours. Set up an inbox alias if you have to.

Evidence: *Email alias / monitoring setup*

Vendor relationships

☐ **12.8.2 Written agreement with each provider**

Your contract with the payment processor and any other PCI-relevant supplier needs to specifically say they're responsible for the security of cardholder data they handle.

Evidence: *Signed contracts referencing PCI responsibilities*

☐ **12.8.4 Track supplier compliance status**

Keep a one-row spreadsheet per supplier: name, what they do, their PCI level, when their AOC was last issued, when it expires.

Evidence: *Supplier compliance tracker spreadsheet*

Phone payments (if applicable)

☐ **phone.1 Take any payments over the phone?**

If yes — even occasionally — SAQ A doesn't cover it. The agent typing the card number into a CRM brings the entire call into PCI scope. You need a descope solution like Paytia, or you'll need to complete SAQ D instead.

Evidence: *Either no phone payments, or a phone-payment descope solution in place*

SECTION 3 · ~70 CONTROLS

SAQ A-EP

E-commerce with iframe/redirect. For online merchants whose own checkout page loads a third-party payment iframe or initiates the redirect — your server is in scope.

SAQ A-EP — Checklist

Roughly 70 controls. Significantly more than SAQ A because your web infrastructure has to be hardened and monitored.

Scope & eligibility

☐ **scope.1 E-commerce only with partial outsourcing**

SAQ A-EP is for online merchants who use a third-party payment page (iframe or redirect) but where your own webpage is what loads the iframe. Your server is in scope because a compromised page could redirect the customer somewhere malicious.

☐ **scope.2 No card data ever touches your environment**

Your server never sees the PAN. If it does, you're on SAQ D, not A-EP.

Build and maintain a secure network

☐ **1.2 Restrict inbound and outbound traffic**

Firewall rules between your web server and the rest of the world should block everything except what's explicitly allowed. Document each rule with a business reason.

Evidence: *Firewall rule list + last review date*

☐ **1.4 Personal firewalls on portable computing devices**

Any laptop that connects to your environment from outside the office needs a host firewall (Windows Defender Firewall is fine, just configured properly).

Evidence: *Endpoint config baseline document*

☐ **2.1 Change vendor-supplied defaults**

Default passwords on routers, admin accounts, database installs — change all of them before going live. The 'admin/admin' router behind your office network counts.

Evidence: *Hardening checklist for each system*

☐ **2.3 Encrypt non-console admin access**

SSH, RDP, web admin panels — all over TLS or stronger. Telnet is dead.

Protect cardholder data

☐ 4.1 Encrypt cardholder data in transit

Even though card data shouldn't touch your server, the redirect/iframe must use TLS 1.2 or above. Disable older protocols.

Evidence: *SSL Labs scan showing A or A+*

Vulnerability management

☐ 5.1 Anti-malware on all systems

Every server and workstation that's commonly affected by malware needs anti-malware software, kept up to date.

☐ 6.1 Process for identifying vulnerabilities

Subscribe to security mailing lists (US-CERT, your OS vendor, your CMS vendor). Someone reads them weekly.

☐ 6.2 Patch within one month of release

Critical security patches go on within a month. Track them in a ticket system so you can show the auditor.

Evidence: *Patch log with dates*

☐ 6.4 Separate dev/test/prod environments

Production runs on different infrastructure from staging. Live card data never appears in test environments.

☐ 6.6 Web application firewall OR code review

Either run a WAF in front of the web server, or get the code reviewed by someone qualified before each release.

Access control

☐ 7.1 Restrict access to data by job role

Define which job roles can access which systems. Default to 'no access' and grant explicitly.

Evidence: *Access matrix per role*

☐ 8.2 Strong authentication for all users

Passwords meet a minimum length (12+ characters is sensible). MFA for any admin access and any remote access.

☐ 8.3 Multi-factor authentication for non-console admin

Anyone administering the environment from outside the office network — MFA is non-negotiable.

Monitoring & testing

☐ **10.2 Audit logs for all in-scope systems**

Log every admin action, every login attempt, every change to user accounts. Keep logs for at least a year, with at least 90 days immediately available.

☐ **11.2 Quarterly external vulnerability scans**

Use an Approved Scanning Vendor (ASV). Scan your external IPs every three months and after any major change.

Evidence: *ASV scan reports for last 4 quarters*

☐ **11.3 Annual penetration test**

Once a year, get a CREST or equivalent pen test against your in-scope environment. Plus after any significant change.

Evidence: *Annual pen test report*

SECTION 4 · ~40 CONTROLS

SAQ B

Imprint and dial-out terminals. For merchants whose only card payments come through old-school imprint machines or standalone payment terminals that dial out over PSTN.

SAQ B — Checklist

Roughly 40 controls. Most of the work is physical security and inspecting devices for tampering.

Scope & eligibility

- ☐ **scope.1 Imprint machines or standalone dial-out terminals only**

SAQ B covers merchants with old-school imprint machines (the carbon-copy zip-zap) or standalone payment terminals that dial out via PSTN. No internet-connected terminals. No e-commerce. No phone payments through a soft phone.
 - ☐ **scope.2 No electronic storage of cardholder data**

If you store imprint slips in a locked cabinet, fine. If you scan them or type them into a computer, you've broken SAQ B scope.
-

Physical security of the device

- ☐ **9.1 Restrict physical access to terminals**

Terminals are kept in areas that aren't accessible to the general public — behind the counter, not on the customer side.
 - ☐ **9.5 Inventory of devices**

List every terminal: make, model, serial number, location. Update when devices are moved, replaced, or retired.
Evidence: *Terminal inventory document*
 - ☐ **9.9 Inspect terminals for tampering**

Train staff to spot a skimmer or modified terminal. Inspect daily and log it. The log doesn't need to be fancy — a tick-box per terminal per day is enough.
Evidence: *Daily inspection log*
-

Paper and receipts

- ☐ **9.6 Physical security of paper records**

Imprint slips and merchant copies of receipts go in a locked drawer or safe. Not in a tray on the counter.
 - ☐ **9.8 Destroy paper records when no longer needed**

Cross-cut shred or pulp anything containing card data when you don't need it any more. A stationery shredder is fine if it's cross-cut.
Evidence: *Destruction log or witnessed-destruction certificate*
-

☐ **3.2 Never store the full magnetic stripe, CVV, or PIN**

Even if your old terminal somehow records it, don't keep printed copies. Truncated PAN (last 4 digits) is fine on receipts.

Policy & people

☐ **12.1 Information security policy**

Same as SAQ A — one document, signed by a director, reviewed annually. For SAQ B it can be very short because the environment is so simple.

Evidence: *Signed policy document*

☐ **12.6 Security awareness training**

Every staff member who handles cards gets trained on PCI basics when they start, and a refresh once a year. Keep a sign-off sheet.

Evidence: *Training records*

☐ **12.10.1 Incident response plan**

Two pages. Who to call if a terminal looks tampered with. Who to call if you suspect a breach. Test it once a year.

SECTION 5 · 330+ CONTROLS (HIGH-IMPACT SUBSET)

SAQ D

The catch-all SAQ. If your environment doesn't fit any of the narrower questionnaires, you're on SAQ D — including most phone-payment merchants without a descope solution.

SAQ D — Checklist (high-impact subset)

The full SAQ D covers 330+ controls. This checklist focuses on the high-impact ones that catch most merchants out — the questions a QSA will lean on hardest.

Phone payments? Read this first. Most merchants land on SAQ D because they take card payments over the phone and the agent types the number into a CRM — bringing calls, recordings, and the office network into scope. A descope solution like Paytia typically reduces SAQ D scope back to SAQ A — fewer controls, fewer audits, less risk. paytia.com/phone-payments

Scope warning — read first

☐ **scope.1 You're on SAQ D because nothing simpler fits**

SAQ D is the catch-all. If you store, process, or transmit cardholder data in a way that doesn't fit A, A-EP, B, B-IP, C-VT, C, or P2PE — you're on D. The scope is your full Cardholder Data Environment plus everything connected to it.

Network & firewalls (Req 1)

☐ **1.1.4 Firewall between any wireless network and the CDE**

If your office WiFi can reach the systems handling card data, you have a problem. Either segment WiFi off entirely or treat it as in-scope (you don't want the latter).

☐ **1.2.1 Restrict inbound and outbound traffic to that necessary**

Default deny. Each allow rule needs a documented business justification and an owner.

☐ **1.3.6 Database servers in an internal network zone, not the DMZ**

Card-data databases are not directly accessible from the internet. Web servers in DMZ talk to DB in internal zone via tightly restricted rules.

Configuration management (Req 2)

☐ **2.1 Change vendor defaults**

Default passwords, default community strings, default service accounts — change all before deploying.

☐ **2.2 Hardening standards for each system type**

One hardening standard per OS / service type, based on a recognised baseline (CIS, NIST). Every new system built to that standard.

☐ **2.6 One primary function per server**

Don't run the database, web server, and mail server on the same host. Either separate hosts or strong virtualisation isolation.

Cardholder data protection (Req 3 + 4)

☐ **3.2 Don't store sensitive authentication data after authorisation**

Full magstripe, CVV, PIN — never stored, even encrypted. The moment after authorisation, it's gone.

☐ **3.3 Mask PAN when displayed**

Show first 6 + last 4 at most, by default. Full PAN visible only to those with a documented business need.

☐ **3.4 Render stored PAN unreadable**

Strong encryption with proper key management, or one-way hashing, or truncation, or tokenisation. Don't roll your own crypto.

☐ **3.5 Document and protect cryptographic keys**

Keys are stored in HSMs or equivalently protected. Key custodians have signed responsibility statements.

☐ **4.1 Encrypt cardholder data in transit over public networks**

TLS 1.2 or above. Disable weak ciphers. Annual SSL Labs scan should be A or A+.

Vulnerability management (Req 5 + 6)

☐ **5.1 Anti-malware on commonly-affected systems**

Endpoint protection on workstations and servers. Updates automatic. Logs sent to central monitoring.

☐ **6.2 Patch within one month of release**

Critical patches go on within a month. Tracked in a ticketing system with deployment dates.

☐ **6.5 Address common coding vulnerabilities**

Developers trained in secure coding (OWASP Top 10 minimum). Code reviews check for the common stuff. SAST/DAST tooling helps but isn't sufficient alone.

☐ **6.6 WAF or code review for public-facing web apps**

Either a WAF in front of every public-facing web app, or every code change reviewed by qualified personnel.

Access control (Req 7 + 8 + 9)

☐ **7.1 Need-to-know access**

Default deny. Access granted by job role. Reviewed at least every 6 months.

☐ **8.3 Multi-factor authentication for all admin and remote access**

MFA for every admin login. MFA for every remote access into the network. Push notifications or hardware tokens, not SMS.

☐ **8.5.1 No shared accounts**

Every person has their own login. No 'admin' account that three people use.

☐ **9.1 Physical access controls to systems**

Server rooms locked. Access logged. Visitors escorted.

Logging & monitoring (Req 10)

☐ **10.2 Log security-relevant events on every in-scope system**

Logins, admin actions, access to cardholder data, changes to user accounts, system clock changes, log access, all critical errors.

☐ **10.5.5 File integrity monitoring on critical files**

FIM on system binaries, configuration files, and audit logs themselves. Alerts on unauthorised change.

☐ **10.6 Daily log review for security events**

Either a SIEM with alerting or a person who genuinely reviews the daily summary. Document who did the review and what they found.

☐ **10.7 Retain audit logs for at least one year**

Three months immediately available, the rest in colder storage.

Testing & pen testing (Req 11)

☐ **11.2 Quarterly external ASV scans**

Approved Scanning Vendor scans every quarter and after significant change. Address findings.

☐ **11.2.1 Quarterly internal vulnerability scans**

Internal scans by qualified personnel. Same cadence as external.

☐ **11.3 Annual external + internal pen tests**

Full pen test once a year and after significant change. Methodology documented. Findings tracked to closure.

☐ **11.5 Change-detection mechanism**

Detect unauthorised modification of system files, config files, content files. Alert on change. Investigate.

Policy & programme (Req 12)

☐ **12.1 Maintain an information security policy**

Comprehensive policy covering all 12 PCI requirements. Reviewed annually. Distributed to staff.

☐ **12.3 Acceptable use policies for technologies**

Policies for laptops, tablets, removable media, internet, email — covering authorised use, owners, accepted use, network locations.

☐ **12.6 Security awareness programme**

Training at hire and annually. Multiple methods (email, posters, training modules). Sign-off after each training.

☐ **12.8 Manage service providers**

List all third parties with access to cardholder data. Written agreements. Annual AOC review. Document who's responsible for what (you vs them).

☐ **12.10 Incident response plan**

Documented, tested annually, includes notification of card brands and acquirer, roles assigned, communication procedures.

SECTION 6 · 15 TERMS

PCI Glossary

The terms you'll see most often when you're working through a SAQ — in plain English.

Glossary

PAN Primary Account Number

The 16-digit (or sometimes 13–19) card number printed on the front of a payment card. The single most regulated piece of data in PCI DSS.

CHD Cardholder Data

PAN, plus optionally cardholder name, expiry date, and service code. Storing or transmitting any of these brings you into scope.

SAD Sensitive Authentication Data

Full magstripe contents, CVV/CVC2, and PIN block. PCI DSS forbids storing SAD after authorisation, even if encrypted.

CVV / CVC2 / CID

The 3- or 4-digit security number printed on the card (not encoded in the magstripe). Used to verify card-not-present transactions. Never stored after authorisation.

CDE Cardholder Data Environment

Every system, network, person, and process that stores, processes, or transmits cardholder data — plus everything connected to it. The smaller you keep your CDE, the less PCI work you have.

Descope

Architectural changes that remove cardholder data from a system or process so it falls outside PCI scope. Phone-payment descope solutions intercept card details before they reach the agent or call recording.

SAQ Self-Assessment Questionnaire

The form a merchant completes annually to attest PCI compliance. Nine variants (A, A-EP, B, B-IP, C-VT, C, P2PE, D-Merchant, D-Service Provider) covering different environments.

AOC Attestation of Compliance

A signed declaration that an entity (merchant or service provider) has completed its PCI assessment and meets requirements. You collect AOCs from your service providers annually.

ASV Approved Scanning Vendor

A PCI-Council-approved third party that runs quarterly external vulnerability scans against your internet-facing systems.

QSA Qualified Security Assessor

An individual or firm certified by the PCI Council to conduct on-site PCI DSS assessments. Required for Level 1 merchants; optional but useful for smaller ones.

ROC Report on Compliance

The full assessment report a QSA produces for Level 1 merchants. Replaces the SAQ for those merchants.

P2PE Point-to-Point Encryption

A PCI-validated approach where card data is encrypted at the point of capture (e.g. inside a payment terminal) and only decrypted by the processor. Massively reduces merchant scope.

Tokenisation

Replacing the PAN with a non-sensitive equivalent (a token) that has no exploitable value. Lets merchants reference customer cards (e.g. for refunds) without storing the PAN.

DTMF masking

Phone-payment technique where the customer types card details on their handset keypad and the DTMF tones are intercepted, captured by a PCI-compliant payment system, and replaced with masked tones in the call recording. The agent never hears or sees the card data.

Acquirer

The bank or financial institution that processes card payments on a merchant's behalf and ultimately decides whether the merchant is PCI-compliant.

ABOUT PAYTIA

Phone payments that **stay out of scope.**

We're Paytia. We build PCI-compliant secure phone payment systems for call centres, contact centres, and merchants who take card payments over the phone.

We open-sourced this checklist because most PCI guidance is written for QSAs, not the people actually trying to get compliant. If it helped you scope your assessment, we've done our job.

If you take card payments over the phone, the agent typing the number into a CRM brings the whole call into PCI scope. Paytia removes the cardholder data from the agent and the recording entirely — typically reducing scope from SAQ D back to SAQ A.

paytia.com/phone-payments

Interactive checklist · paytia-comply.github.io/paytia-saq-checklist

Open source on GitHub · github.com/paytia-comply/paytia-saq-checklist